

**Министерство науки и высшего образования Российской Федерации
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ
УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО**

Факультет безопасности информационных технологий

Дисциплина:

«Технология обнаружения уязвимостей в автоматизированных системах»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №2

«CVE-2021-44228 (Log4Shell)»

Выполнили:

Чу Ван Доан, студент группы N3447



(подпись)

Проверил:

к.т.н., доц., Менщиков Александр Алексеевич

(отметка о выполнении)

(подпись)

Санкт-Петербург

2025 г.

СОДЕРЖАНИЕ

Содержание.....	2
Введение.....	3
1 Ход работы.....	4
1.1 CVE.....	4
1.2 CVSSv4 (подробно).....	4
1.3 CWE.....	5
1.4 Подходящие техники MITRE ATT&CK.....	5
1.5 Статус наличия эксплойта.....	5
1.6 Перечень диапазонов уязвимых версий.....	5
Заключение.....	7
Список использованных источников.....	8

ВВЕДЕНИЕ

Цель работы - Исследовать и документировать уязвимость CVE-2021-44228 (Log4Shell) в Apache Log4j 2: установить её техническую природу и условия эксплуатации (JNDI/EL-инъекция → RCE), выполнить оценку риска по CVSS v4.0, определить наиболее точную CWE-классификацию (приоритетно CWE-917, при необходимости — сопутствующие), сопоставить с релевантными техниками MITRE ATT&CK, зафиксировать статус наличия/зрелости эксплойтов и полный перечень уязвимых/исправленных версий, а также предложить практические меры обнаружения и снижения риска для защищаемых систем.

Для достижения поставленной цели необходимо решить следующие задачи:

1. CVE
2. CVSSv4 (подробно)
3. CWE
4. Подходящие техники [MITRE ATT&CK](#), в рамках которых эта уязвимость могла быть использована
5. Статус наличия эксплойта
6. Перечень диапазонов уязвимых версий

1 Ход работы

1.1 CVE

- CVE-2021-44228 (Log4Shell) — уязвимость RCE до аутентификации в Log4j 2, связанная с механизмом JNDI, который позволяет загружать код из LDAP/... когда злоумышленник контролирует строку журнала, что приводит к выполнению кода на сервере.

1.2 CVSSv4 (подробно)

Итоговый балл: 9.3 / Critical

Вектор:

CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N

The image shows the CVSS v4.0 Calculator interface. At the top, the CVSS logo is displayed. Below it, the title "Common Vulnerability Scoring System Version 4.0 Calculator" is shown. A green bar contains the input vector: "CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N". A "Reset" button is located to the right of the vector input. Below the vector input, the calculated score is displayed: "CVSS v4.0 Score: 9.3 / Critical". The main part of the interface is a form with three sections: "Exploitability Metrics", "Vulnerable System Impact Metrics", and "Subsequent System Impact Metrics". Each section contains a list of metrics with buttons for selecting their values. The selected values for the given vector are: AV:N, AC:L, AT:N, PR:L, UI:N, VC:H, VI:H, VA:H, SC:N, SI:N, SA:N.

Exploitability Metrics			
Attack Vector (AV):	Network (N)	Adjacent (A)	Local (L)
Attack Complexity (AC):	Low (L)	High (H)	
Attack Requirements (AT):	None (N)	Present (P)	
Privileges Required (PR):	None (N)	Low (L)	High (H)
User Interaction (UI):	None (N)	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	High (H)	Low (L)
Integrity (VI):	High (H)	Low (L)
Availability (VA):	High (H)	Low (L)

Subsequent System Impact Metrics		
Confidentiality (SC):	High (H)	Low (L)
Integrity (SI):	High (H)	Low (L)
Availability (SA):	High (H)	Low (L)

Рисунок 1 - CVSSv4

- AV:N, AC:L, PR:N, UI:N — эксплуатация по сети, не требуются редкие условия, учётная запись и взаимодействие пользователя не нужны.

VC/VI/VA:H — произвольное выполнение кода ⇒ высокий эффект на C/I/A затронутой системы.

SC/SI/SA:N — сама уязвимость не подтверждает влияние на «последующие

системы». Оценка по FIRST CVSS v4 (спецификация + калькулятор).
Справка: официальная оценка CVSS v3.1 на NVD — 10.0 (CRITICAL)
AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H.

1.3 CWE

- CWE (основной): CWE-917 — неправильная нейтрализация специальных элементов, используемых в выражении языка (Expression Language Injection) — по данным NVD/NIST для CVE-2021-44228.
- CWE (дополнительный): CWE-502 (десериализация в цепочке JNDI).
- CWE-20 и CWE-400 упоминаются Apache как сопутствующие аспекты; CWE-400 больше соответствует варианту DoS CVE-2021-45105.

1.4 Подходящие техники MITRE ATT&CK

- T1190 — Exploit Public-Facing Application: эксплуатация публичного приложения/ПО (Java-веб-сервис, использующий Log4j).
- T1059 — Command and Scripting Interpreter: после получения RCE злоумышленник выполняет команды/скрипты на машине жертвы.
- T1105 — Ingress Tool Transfer: загрузка/перенос инструментов во внутреннюю систему после первоначального проникновения.

1.5 Статус наличия эксплойта

- Широко эксплуатировалась; имеются публичные PoC/модули (сканеры, эксплойты); включена в каталог CISA KEV.

1.6 Перечень диапазонов уязвимых версий

- Log4j 2: с 2.0-beta9 по 2.14.1 (консенсус NVD/CISA/NCSC).
- Примечание: версия 2.15.0 по умолчанию устраняет проблему, но затем последовали дополнительные корректировки (45046/45105); рекомендуется обновиться до $\geq 2.16.0/2.17.x$ в зависимости от ветки.

ЗАКЛЮЧЕНИЕ

В рамках работы по CVE-2021-44228 (Log4Shell) выполнены все требуемые шесть шагов: идентифицирована уязвимость и её механизм (инъекция в выражение/JNDI → RCE pre-auth), проведена оценка риска по CVSS v4.0 (критический уровень с сетевым вектором и низкой сложностью), определена точная CWE-классификация (приоритетно CWE-917, дополнительно CWE-502/20/400 по контексту), сопоставлены релевантные техники MITRE ATT&CK (T1190, T1059, T1105), подтверждён статус активной эксплуатации (наличие PoC/KEV) и перечислены диапазоны уязвимых версий Log4j 2 (2.0-beta9...2.14.1) с рекомендациями по обновлению.

С практической точки зрения Log4Shell остаётся показательной RCE-уязвимостью цепочки поставок: маленькая библиотека приводит к системному компромиссу множества сервисов. Ключевые выводы и меры:

- Приоритет — немедленное обновление до исправленных веток ($\geq 2.16.0/2.17.x$ в зависимости от платформы) по официальным рекомендациям.
- Если обновление временно невозможно: удалить JndiLookup из уязвимых JAR, отключить JNDI-lookups на уровне конфигурации, ограничить egress-трафик (LDAP/RMI/DNS) для JVM-хостов.
- Мониторинг и детектирование: поиск паттернов `{jndi:` в логах/заголовках, аномального исходящего LDAP/RMI/DNS, артефактов последующей загрузки/скриптинга.
- Процессно: внедрить SCA/SBOM и регулярный трекинг зависимостей, egress-контроль по умолчанию, тесты безопасности в CI/CD, регламент быстрого патч-менеджмента.

Итог: уязвимость требует статуса Critical и постоянного контроля. Комбинация своевременных обновлений, жёстких сетевых и конфигурационных ограничений и проактивного мониторинга существенно снижает вероятность успешной эксплуатации и масштабы последствий.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. [NVD - cve-2021-44228](#)
2. [Common Vulnerability Scoring System Version 4.0 Calculator](#)
3. [CWE-917: Improper Neutralization of Special Elements used in an Expression Language Statement \('Expression Language Injection'\)](#)
4. [CWE-20: Improper Input Validation \(4.18\)](#)
5. [CWE-400: Uncontrolled Resource Consumption \(4.18\)](#)
6. [CWE-502: Deserialization of Untrusted Data \(4.18\)](#)